Security assessment report

Target: http://127.0.0.1:8081/

Started: 2026-08-27 09:35:09

C

72/100
score = 100 – penalties (High 15, Medium 8, Low 3)

0 Critical	0 High	2 Medium	6 Low	3 Informational

Summary of findings

Severity	Category	Finding
Medium	A05:2021 – Security Misconfiguration	Missing browser security policy: Content-Security-Policy
Medium	A02:2021 – Cryptographic Failures	HTTPS not enabled on target URL
Low	A05:2021 – Security Misconfiguration	Missing browser security policy: X-Frame-Options
Low	A05:2021 – Security Misconfiguration	Missing browser security policy: X-Content-Type-Options
Low	A05:2021 – Security Misconfiguration	Missing browser security policy: Referrer-Policy
Low	A05:2021 – Security Misconfiguration	Missing browser security policy: Permissions-Policy
Low	A05:2021 – Security Misconfiguration	Cookie missing Secure attribute
Low	A05:2021 – Security Misconfiguration	Cookie missing HttpOnly attribute
Informational	A05:2021 – Security Misconfiguration	Server technology disclosure
Informational	Phishing / impersonation (outside OWASP Top 10)	URL reputation heuristic: low risk
Informational	Other / tool output	OWASP ZAP not configured

Details and recommendations

1. [Medium] Missing browser security policy: Content-Security-Policy

Source: Browser Security · **URL:** http://127.0.0.1:8081/

Description: Helps restrict script, object, frame and resource sources.

Evidence: `HTTP 200; Content-Security-Policy header absent.`

Recommendation: Configure Content-Security-Policy appropriately for the application.

2. [Medium] HTTPS not enabled on target URL

Source: TLS Scanner · **URL:** http://127.0.0.1:8081/

Description: The supplied target uses HTTP rather than HTTPS.

Evidence: `http://127.0.0.1:8081/`

Recommendation: Use HTTPS for sensitive traffic and redirect HTTP to HTTPS where appropriate.

3. [Low] Missing browser security policy: X-Frame-Options

Source: Browser Security · **URL:** http://127.0.0.1:8081/

Description: Helps prevent clickjacking when CSP frame-ancestors is not used.

Evidence: `HTTP 200; X-Frame-Options header absent.`

Recommendation: Configure X-Frame-Options appropriately for the application.

4. [Low] Missing browser security policy: X-Content-Type-Options

Source: Browser Security · **URL:** http://127.0.0.1:8081/

Description: Prevents MIME-type sniffing when set to nosniff.

Evidence: `HTTP 200; X-Content-Type-Options header absent.`

Recommendation: Configure X-Content-Type-Options appropriately for the application.

5. [Low] Missing browser security policy: Referrer-Policy

Source: Browser Security · **URL:** http://127.0.0.1:8081/

Description: Controls how much referrer information browsers send.

Evidence: `HTTP 200; Referrer-Policy header absent.`

Recommendation: Configure Referrer-Policy appropriately for the application.

6. [Low] Missing browser security policy: Permissions-Policy

Source: Browser Security · **URL:** http://127.0.0.1:8081/

Description: Restricts access to browser capabilities such as camera or microphone.

Evidence: `HTTP 200; Permissions-Policy header absent.`

Recommendation: Configure Permissions-Policy appropriately for the application.

7. [Low] Cookie missing Secure attribute

Source: Cookie Security · **URL:** http://127.0.0.1:8081/

Description: Cookie lab_session is not marked Secure.

Evidence: `lab_session`

Recommendation: Set Secure on cookies that should only travel over HTTPS.

8. [Low] Cookie missing HttpOnly attribute

Source: Cookie Security · **URL:** http://127.0.0.1:8081/

Description: Cookie lab_session is not marked HttpOnly.

Evidence: `lab_session`

Recommendation: Set HttpOnly on session cookies that do not need JavaScript access.

9. [Informational] Server technology disclosure

Source: Browser Security · **URL:** http://127.0.0.1:8081/

Description: The response exposes a Server header that may assist fingerprinting.

Evidence: `Werkzeug/3.1.9 Python/3.13.16, LabServer/1.0`

Recommendation: Minimize unnecessary version and product disclosure.

10. [Informational] URL reputation heuristic: low risk

Source: URL Risk Analyzer · **URL:** http://127.0.0.1:8081/

Description: LOW RISK (HEURISTIC CHECK)

Evidence: `Heuristic score 25/100.`

Recommendation: This is not proof that a website is legitimate; verify ownership and reputation separately.

11. [Informational] OWASP ZAP not configured

Source: OWASP ZAP · **URL:** http://127.0.0.1:8081/

Description: ZAP_PATH is not set, so the ZAP stage was skipped.

Evidence: `ZAP_PATH environment variable missing.`

Recommendation: Configure ZAP_PATH to the ZAP startup script (for Windows, normally zap.bat).